



ESTADO DO MARANHÃO
SECRETARIA DE ESTADO DA SEGURANÇA PÚBLICA
POLÍCIA MILITAR DO MARANHÃO
COMANDO DO POLICIAMENTO DE ÁREA I/2
18º BATALHÃO DE POLÍCIA MILITAR
Rua do Sol, S/N, Cohab, Presidente Dutra-MA, CEP 65.760-000

SIGEP — 18º BPM

Dossiê técnico para o Comando

Sistema Integrado de Gestão de Pessoal — 18º Batalhão de Polícia Militar

Presidente Dutra — MA · Comando do Policiamento de Área I/2 · Polícia Militar do Maranhão

Documento de apoio para reunião de comando. Descreve o que o sistema é, como está construído, como os dados são protegidos e quais são os pontos de atenção. Tudo aqui corresponde ao que está efetivamente implantado e em funcionamento — não a plano futuro.

1. O que o sistema resolve

O SIGEP substitui o controle em papel, planilhas soltas e grupos de WhatsApp por **uma única fonte de verdade** para a gestão de pessoal do Batalhão.

Antes	Depois
Escala digitada e reenviada a cada correção	Escala publicada; a última versão sempre prevalece , com histórico de todas
Ficha do militar em planilha, cada seção com a sua	Cadastro único , com antiguidade, lotação, promoções e afastamentos
Plano de férias em papel, memorando digitado um a um	Plano por equipes, memorando gerado e assinado eletronicamente
Permuta pedida no grupo, sem registro	Pedido, autorização e documento com QR de verificação
"Quem está de serviço amanhã?"	O policial abre o celular e vê

Em números (hoje): 203 militares no plano de férias · 9 equipes · 49 telas · 90 rotas de serviço · 25 tabelas no banco.

2. Arquitetura

2.1 Visão geral



```
Navegador / celular do policial
| HTTPS (TLS obrigatório)
v
+-----+
| Aplicação SIGEP (Vercel) | Next.js 14 · React 18 · TypeScript
| · Páginas renderizadas no | Execução serverless – sem servidor
| servidor                  | físico no quartel para manter
| · 90 rotas de API          |
+-----+
|           |           |
v           v           |
+-----+ +-----+
| PostgreSQL | | Cloudflare R2 |
| (Neon)     | | fotos e anexos |
| dados      | | (links assinados |
|            | | com validade)  |
+-----+ +-----+
```

2.2 Tecnologia empregada

Camada	Solução	Observação
Interface	Next.js 14 (App Router), React 18, TypeScript, Tailwind CSS	Funciona no computador e no celular, sem instalar aplicativo
Servidor	Funções serverless na Vercel	Escala sozinho; sem máquina para o Batalhão administrar
Banco de dados	PostgreSQL gerenciado (Neon), via Prisma ORM	25 tabelas; consultas parametrizadas (imunes a injeção de SQL)
Autenticação	NextAuth 4 com sessão JWT	Sem senha trafegando depois do login
Arquivos	Cloudflare R2 (compatível S3)	Upload direto do navegador por link temporário assinado
Notificações	Web Push (padrão VAPID)	Chega no celular mesmo com o sistema fechado
Voz e vídeo	WebRTC ponto a ponto	A mídia não passa pelo servidor
Documentos	Geração nativa de .docx e PDF	Memorandos, escalas, certidões, portarias

2.3 Por que na nuvem, e não num servidor do quartel

- **Sem ponto único de falha físico** — não depende de energia, ar-condicionado ou rede do prédio.
- **Sem custo de manutenção de hardware** e sem necessidade de um militar dedicado à administração de servidor.
- **Atualização de segurança contínua** da plataforma, sem janela de parada.
- **Acesso de qualquer lugar** — o policial de folga consulta a escala pelo celular.
- Os dados permanecem **de propriedade da Corporação**; há exportação completa a qualquer momento (item 5).



3. Controle de acesso

3.1 Identificação

- O login é o **ID PMMA** do militar (aceita também a matrícula, para quem já usava).
- Só entra quem está com o cadastro **ativo**; o desligamento no cadastro corta o acesso.
- **Troca de senha obrigatória no primeiro acesso** — imposta pelo servidor, não é possível contornar navegando.

3.2 Senhas

Item	Como está
Armazenamento	bcrypt (custo 10). A senha não é recuperável , nem pelo administrador
Legado	Senhas do sistema antigo migram sozinhas para bcrypt no próximo login, sem incomodar o usuário
Política	Mínimo 8 caracteres, obrigando misturar letras com números ou símbolos
Bloqueios	Recusa sequências óbvias (12345678), caractere repetido e qualquer senha que contenha o próprio login ou ID

3.3 Proteção contra tentativa de invasão

- **5 erros de senha -> conta bloqueada por 15 minutos.**
- Cada tentativa registra **IP, data e hora, localização aproximada, fuso, idioma, plataforma e navegador**.
- Tela dedicada de **Tentativas de Acesso** para o administrador.
- Conta bloqueada **dispara alerta no sininho** do administrador em até 24 h.

3.4 Sessão

- **Logout automático por inatividade:** 60 minutos para administrador, 30 minutos para policial.
- Relógio de sessão **visível na tela**, contando o tempo restante.
- Protege o computador compartilhado deixado aberto na seção.

3.5 Perfis e alcance da informação

Perfil	O que alcança
Administrador (P/1 e auxiliares)	Gestão completa: efetivo, escalas, férias, disciplinar, governança
Cmt / Sargenteante de unidade destacada	Somente a própria unidade — escala, organograma e lotação dela
Policial	Somente os próprios dados : sua ficha, sua escala, suas férias, suas certidões

A verificação é feita **no servidor**, em cada página e em cada rota — não é apenas o menu que esconde. Um policial que digitasse o endereço de uma tela administrativa é redirecionado para a própria ficha.

Princípio da minimização (LGPD): o policial não vê os dados dos outros. Em "Minhas Férias" ele vê os colegas da própria equipe apenas com posto e nome — o necessário para se organizar, nada além.



4. Proteção dos dados

4.1 Em trânsito

- **HTTPS obrigatório, com HSTS de 2 anos e preload** — o navegador se recusa a abrir o sistema sem criptografia, mesmo que alguém tente forçar.

4.2 Em repouso

- **CPF, banco, agência e conta** ficam cifrados no banco com **AES-256-GCM** (padrão militar/bancário). Quem obtivesse acesso bruto ao banco veria texto cifrado nesses campos.
- Migração transparente: valores antigos são cifrados na próxima gravação.

4.3 Defesas do navegador (cabeçalhos de segurança)

Cabeçalho	O que impede
Content-Security-Policy	Carregar script ou conteúdo de site externo; enviar dados para fora
X-Frame-Options: DENY + frame-ancestors 'none'	Que o sistema seja embutido em site falso (<i>clickjacking</i>)
Strict-Transport-Security	Acesso sem criptografia
X-Content-Type-Options: nosniff	Arquivo malicioso se passar por outro tipo
Referrer-Policy	Vazamento de endereço interno para sites de terceiros
Permissions-Policy	Câmera, microfone e localização para terceiros — liberados só para o próprio sistema

4.4 Anexos do chat

- O arquivo vai do **navegador direto para o armazenamento**, por **link assinado com validade de 15 minutos**. Não trafega pelo servidor da aplicação.
- Limite de 20 MB por arquivo.

5. Auditoria, backup e continuidade



5.1 Trilha de auditoria

Tabela própria e permanente, registrando em cada ação sensível:

quem fez · o que fez · sobre quem · de que IP · quando · como estava antes · como ficou depois

Cobre login, tentativa de senha errada, alteração de ficha, assinatura de documento, geração de backup, entre outras. Tela de **Auditoria** disponível ao administrador, com filtro.

5.2 Backup

Modalidade	Como funciona
Automático semanal	Toda segunda-feira , o sistema gera o dump completo e envia por e-mail ao responsável — cópia fora da plataforma
Manual	Botão na tela de Governança: baixa o backup completo em JSON, para salvar em pen-drive, Drive ou e-mail
Da plataforma	O banco gerenciado mantém os próprios pontos de restauração

Toda geração de backup **fica registrada na auditoria**.

5.3 Não há aprisionamento a fornecedor

O backup é um arquivo **JSON aberto**, com todos os registros. A Corporação pode, a qualquer momento, levar os dados para outra solução. O código-fonte está versionado em repositório próprio, com histórico completo de cada alteração.

6. Assinatura eletrônica dos documentos

O SIGEP emite documentos **assinados eletronicamente**, com respaldo na **MP 2.200-2/2001** e na **Lei 14.063/2020** (assinatura eletrônica **avançada**).

Como funciona:

1. O signatário **confirma a própria senha** no momento de assinar (reautenticação — não basta estar logado).
2. O sistema calcula o **resumo criptográfico (SHA-256)** do conteúdo exato do documento.
3. Gera um **lacre HMAC-SHA256** com o segredo do sistema, gravando data, hora, nome e cargo.
4. O documento sai com **carimbo e QR Code**.

Verificação: qualquer pessoa — inclusive de fora do Batalhão — aponta a câmera para o QR e o sistema **recalcula o lacre**. Confere = documento **autêntico e íntegro**. Não confere = **foi alterado**. A comparação é feita em tempo constante, sem expor o segredo.

Onde já se aplica: escala de serviço (Chefe do P/1 e VISTO do Comandante), memorando de férias e de licença-prêmio (militar interessado + seção), permutas e certidões.

Fluxo do memorando de férias — exemplo do controle por níveis:



ESTADO DO MARANHÃO
SECRETARIA DE ESTADO DA SEGURANÇA PÚBLICA
POLÍCIA MILITAR DO MARANHÃO
COMANDO DO POLICIAMENTO DE ÁREA I/2
18º BATALHÃO DE POLÍCIA MILITAR
Rua do Sol, S/N, Cohab, Presidente Dutra-MA, CEP 65.760-000

1. O militar assina no celular -----> 2. P/1 e auxiliares são avisados na hora
(confirma a senha)
3. O militar recebe o aviso <----- O chefe da seção assina
de que ficou pronto (confirma a senha)

7. Conformidade com a LGPD (Lei 13.709/2018)

Tela de **Governança e Conformidade** reunindo a parte documental e os controles:

- **Aviso de Privacidade** ao titular
- **Política de retenção e descarte**
- **Designação do Encarregado (DPO)**
- **ROPA** — registro das operações de tratamento
- **Termo de ciência** do policial

Controles técnicos que sustentam a conformidade:

Princípio da LGPD	Como é atendido
Finalidade	Dados usados apenas para a gestão de pessoal do Batalhão
Minimização	Cada perfil vê só o necessário; o policial vê apenas os próprios dados
Segurança	bcrypt, AES-256-GCM, HTTPS/HSTS, bloqueio por tentativa, sessão expirável
Rastreabilidade	Trilha de auditoria com autor, IP e histórico antes/depois
Transparência	Aviso de privacidade e ficha do próprio militar acessível a ele

8. O que o sistema já entrega

Recursos Humanos — cadastro de efetivo, hierarquia, organograma, antiguidade, lotação, ficha individual, promoções e certidões.

Escalas — escala diária da sede e das unidades destacadas, mapa por equipes (24/72), motor automático de rodízio, permutas com documento, publicação com versionamento, estatísticas de carga por militar, redução judicial de escala por percentual.

Férias e Licença-Prêmio — plano por equipes, memorando assinado nas duas pontas, controle de férias adiadas, relatório de vencidas por exercício, férias avulsas — tudo refletindo automaticamente na escala.

Operacional — JOE/RENE, requerimentos, cursos, controle de entrada e saída, verificação pública de documentos.

Disciplinar — FATD, sindicância, IPS e IPM.

Comunicação — chat interno com presença, anexos, ligação de voz e chamada de vídeo; notificações push no celular; avisos do comando.

Governança — auditoria, tentativas de acesso, gestão de acessos, backup, documentação LGPD.



9. Pontos de atenção — declarados com franqueza

Nenhum sistema é perfeito. Estes são os pontos que o Comando deve conhecer, com o encaminhamento de cada um:

Ponto	Situação	Encaminhamento
Sem segundo fator (2FA)	Hoje o acesso é login + senha	Pode ser acrescentado (código por e-mail ou aplicativo autenticador) se o Comando julgar necessário
Chat não auditado	Decisão do próprio Comando: conversa entre militares não é registrada para consulta administrativa	Reversível a qualquer momento, se houver determinação em contrário
Chamada de voz/vídeo entre redes móveis	Pode falhar entre dois aparelhos em 4G sem um servidor intermediário (TURN)	Depende de contratar/installar esse serviço; funciona bem em rede Wi-Fi
Política de conteúdo do navegador	Permite estilos e scripts internos (unsafe-inline), exigência técnica do framework atual	Pode ser endurecida com assinatura por nonce numa próxima versão
Cobertura da auditoria	Cobre as ações sensíveis (login, ficha, assinatura, backup), não as 90 rotas	Ampliação incremental, conforme prioridade do Comando
Dependência de serviços externos	Aplicação, banco e arquivos em provedores de nuvem	Mitigado pelo backup semanal externo e pelo formato aberto de exportação

10. Custos e sustentação

- Construído **sem custo de licença de software** — toda a base é software livre ou plataforma em nível gratuito.
- **Não exige servidor, nobreak, ar-condicionado ou licença de banco de dados** no quartel.
- **Não exige militar dedicado** à administração de infraestrutura.
- Manutenção evolutiva conduzida internamente, com código versionado e histórico completo.

11. Em uma frase, para o Comando

O SIGEP coloca a gestão de pessoal do 18º BPM em uma única base, protegida por criptografia, com trilha de auditoria e documentos eletronicamente assináveis e verificáveis por QR Code — acessível do quartel ou do celular, sem custo de licença e sem servidor para o Batalhão manter.

18º Batalhão de Polícia Militar · Presidente Dutra — MA

Documento gerado a partir da inspeção do sistema em produção.



Como regerar este documento

O Word e o PDF timbrados nascem deste mesmo arquivo. Depois de editar o texto:

```
npm run dossie
```

Gera, com o cabeçalho oficial em todas as páginas:

Arquivo	O que é	Fonte
DOSSIE-COMANDO	Este documento — o técnico completo	DOSSIE-COMANDO.md
RESUMO-COMANDO	Resumo executivo de uma página	RESUMO-COMANDO.md
APRESENTACAO-COMANDO	O que resolve, o que já está pronto e o que falta	APRESENTACAO-COMANDO.md

Nas tabelas, uma célula cujo conteúdo seja só **IMPLANTADO**, **PARCIAL**, **A IMPLANTAR** ou **SE AUTORIZADO** sai como etiqueta colorida.